

API Security Risk Analysis

Cyber Security Task 3 – Future Interns

Name: Ruchith Pathani

Internship Name: Cyber Security internship

Date of Submission: June 2026

CIN: FIT/MAY26/CS8637

Assessment Type: API Security Risk Analysis

INTRODUCTION

This project was completed as part of the Future Interns Cyber Security Internship Program.

The purpose of this task was to perform a security assessment of publicly accessible APIs and identify potential security risks associated with API implementations. The assessment focused on analyzing API responses, exposed data, authentication mechanisms, request headers, and common security weaknesses.

Testing was conducted using Postman in a controlled environment to understand API behavior and evaluate security-related concerns without causing any disruption to the target services.

Objectives

- Understand API security concepts and best practices.
- Analyze API responses and identify exposed information.
- Evaluate authentication and authorization mechanisms.
- Review request and response headers.
- Assess potential security risks associated with APIs.
- Document findings and provide remediation recommendations.

Tools Used

- Postman
- Kali Linux
- Public Test APIs
- Browser Developer Tools
- GitHub

APIs Tested

JSONPlaceholder Users API

Endpoint:

<https://jsonplaceholder.typicode.com/users>

Purpose:

- User Information Analysis
- Data Exposure Assessment
- Authentication Review

JSONPlaceholder Posts API

Endpoint:

<https://jsonplaceholder.typicode.com/posts>

Purpose:

- API Response Analysis
- Data Accessibility Review
- Security Assessment

Testing Methodology

Phase 1 – API Enumeration

The API endpoints were identified and accessed through Postman for analysis.

Activities Performed:

- API Endpoint Discovery
- Response Collection
- Header Inspection
- Data Analysis

Phase 2 – Security Assessment

The collected API responses were examined to identify potential security weaknesses.

Activities Performed:

- Authentication Analysis
- Data Exposure Review
- Header Analysis
- Security Risk Identification

Phase 3 – Risk Analysis

The identified issues were evaluated and categorized based on their potential impact and likelihood of exploitation.

Risk Categories:

- Low
- Medium
- High

Security Findings

1. Lack of Authentication Controls

Risk Level: High

Description:

The API endpoints were accessible without requiring authentication credentials or user verification.

Impact:

Unauthorized users may gain access to information exposed through the API, increasing the risk of misuse and data harvesting.

Recommendation:

Implement strong authentication mechanisms such as:

- JWT (JSON Web Token)
- OAuth 2.0
- API Key Authentication

2. Data Exposure

Risk Level: Medium

Description:

The API responses exposed user-related information, including:

- Names
- Email Addresses
- Phone Numbers
- Address Information

Impact:

Exposed information may assist attackers in reconnaissance activities, social engineering attacks, or targeted phishing campaigns.

Recommendation:

Apply the principle of least privilege and expose only the information required by the application.

3. Missing Rate Limiting Controls

Risk Level: Medium

Description:

No visible request throttling or rate-limiting mechanisms were observed during testing.

Impact:

Attackers may abuse API endpoints through excessive requests, potentially causing service degradation or denial-of-service conditions.

Recommendation:

Implement API rate limiting and request throttling policies.

Example:

100 Requests per Minute per User

4. Security Header Review Required

Risk Level: Low

Description:

API responses should be reviewed regularly to ensure secure header configurations and adherence to security best practices.

Impact:

Improper header configurations may reveal unnecessary information or weaken security controls.

Recommendation:

Review and strengthen API security headers and regularly audit API configurations.

Risk Assessment Summary

Vulnerability	Risk Level
Lack of Authentication Controls	High
Data Exposure	Medium
Missing Rate Limiting Controls	Medium
Security Header Review Required	Low

Screenshots

Users API Analysis

The screenshot displays a REST client interface with the following details:

- Method:** GET
- URL:** `https://jsonplaceholder.typicode.com/users`
- Status:** 200 OK
- Response Body (JSON):**

```
1 {
2   {
3     "id": 1,
4     "name": "Leanne Graham",
5     "username": "Bret",
6     "email": "Sincere@april.biz",
7     "address": {
8       "street": "Kulas Light",
9       "suite": "Apt. 556",
10      "city": "Glenborough",
11      "zipcode": "92998-3874",
12      "geo": {
13        "lat": "-37.3159",
14        "lng": "81.1496"
15      }
16    },
17    "phone": "1-770-736-8031 x56442",
18    "website": "hildgard.org",
19    "company": {
20      "name": "Romaguera-Crona",
21      "catchPhrase": "Multi-layered client-server neural-net",
22      "bs": "harness real-time e-markets"
23    }
24  },
25 }
```

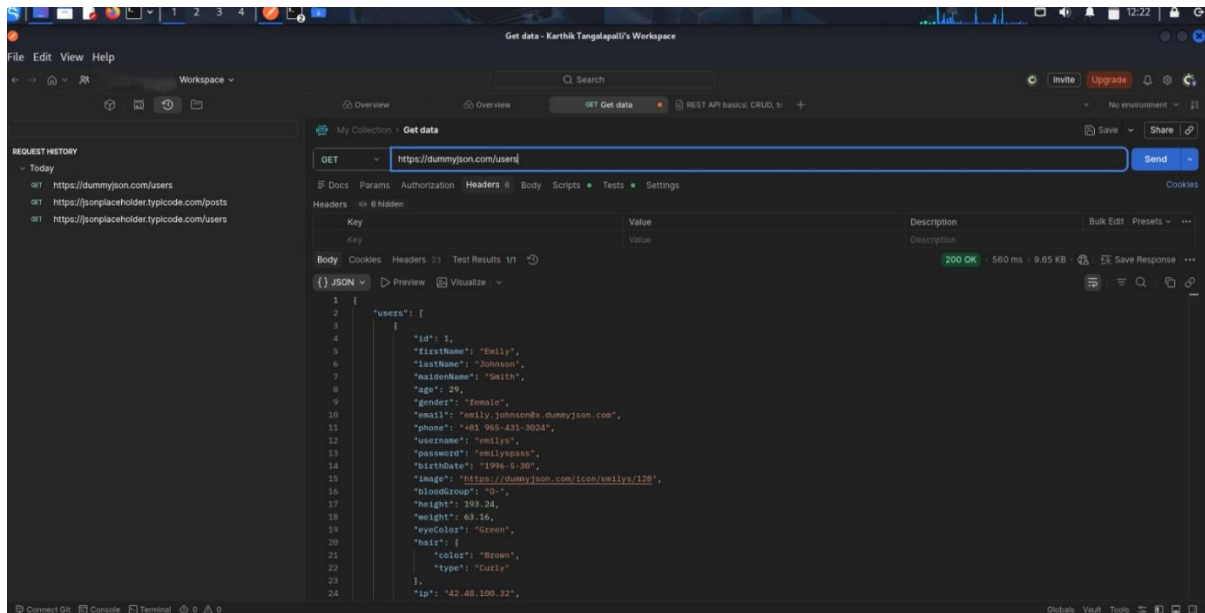
Posts API Analysis

The screenshot displays a REST client interface with the following details:

- Method:** GET
- URL:** `https://jsonplaceholder.typicode.com/posts`
- Status:** 200 OK
- Response Body (JSON):**

```
1 {
2   {
3     "userId": 1,
4     "id": 1,
5     "title": "sunt aut facere repellat provident occaecati excepturi optio reprehenderit",
6     "body": "quia et suscipit\nsuscipit recusandae consequuntur expedita et cum\nreprehenderit molestiae ut ut quas totam\nnostrum rerum est autem sunt rem eveniet architecto"
7   },
8   {
9     "userId": 1,
10    "id": 2,
11    "title": "qui est esse",
12    "body": "est rerum tempore vitae\nsequi sint nihil reprehenderit dolor beatae ea dolores neque\nfugiat blanditiis voluptate porro vel nihil molestiae ut reiciendis\nqui aperiam non debitis possimus qui neque nisi nulla"
13  },
14  {
15    "userId": 1,
16    "id": 3,
17    "title": "ea molestiae quasi exercitationem repellat qui ipsa sit aut",
18    "body": "et iusto sed quo iure\nvoluptatem occaecati omnis eligendi aut ad\nvoluptatem doloribus vel accusantium quis pariatur\nmolestiae porro eius odio et labore et velit aut"
19  },
20  {
21    "userId": 1,
```

Header Inspection



Security Recommendations

1. Implement strong authentication mechanisms.
2. Apply proper authorization controls.
3. Restrict exposure of sensitive information.
4. Enable API rate limiting and throttling.
5. Validate and sanitize user inputs.
6. Secure API request and response headers.
7. Continuously monitor API activity and logs.
8. Conduct periodic API security assessments.

Learning Outcomes

Through this project, the following skills and concepts were strengthened:

- API Security Testing
- API Response Analysis
- Data Exposure Assessment
- Security Risk Identification
- Postman Usage and Testing
- Security Documentation and Reporting
- Cybersecurity Risk Assessment Methodologies

Conclusion

The API Security Risk Analysis successfully demonstrated how publicly accessible APIs can expose information when appropriate security controls are not implemented.

The assessment identified common API security concerns, including authentication weaknesses, data exposure risks, and the absence of rate-limiting mechanisms. Appropriate recommendations were provided to enhance API security and reduce potential attack surfaces.

This project provided valuable hands-on experience in API security testing, security analysis, risk assessment, and professional cybersecurity reporting, further strengthening practical cybersecurity skills and knowledge.